

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО
ОБРАЗОВАНИЯ
«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО»

Факультет безопасности информационных технологий

Направление подготовки: 10.03.01 Информационная безопасность

Образовательная программа: "Информационная безопасность / Information security"

Дисциплина:

«Информационная безопасность баз данных»

КУРСОВАЯ РАБОТА

на тему «Информационная система магазина техники Apple»

Выполнил студент:

N3346 / ИББД_ТЗИ_N3 1.4

Бардышев Артём Антонович /

ФИО

Подпись

Проверил:

Салихов Максим Русланович, преподаватель ФБИТ /

ФИО

Подпись

Отметка о выполнении (один из вариантов:
отлично, хорошо, удовлетворительно)

Дата

Санкт-Петербург

2025г.

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО
ОБРАЗОВАНИЯ
«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО»

ЗАДАНИЕ НА КУРСОВОЙ ПРОЕКТ

Студент	Бардышев А.А.
	(Фамилия, И., О.)
Факультет	Безопасности информационных технологий
Группа	N3346
Направление (специальность)	10.03.01 Информационная безопасность
Руководитель	Салихов Максим Русланович, преподаватель ФБИТ
	(Фамилия, И.О., должность, ученое звание, степень)
Дисциплина	Информационная безопасность баз данных

Наименование темы	<i>Проектирование и реализация информационной системы магазина техники «Apple»</i>
-------------------	--

Задание	<i>Разработать защищенную базу данных и API-сервис для ИС «Магазин техники Apple» с механизмами аутентификации.</i>
---------	---

Краткие методические указания	Выполнить проектирование, реализацию и защиту БД в PostgreSQL (мониторинг, RBAC, шифрование). Разработать API-сервис с использованием ORM и настроить систему резервного копирования.
-------------------------------	---

Содержание пояснительной записки	Инфологическое моделирование; реализация БД в PostgreSQL; защита данных (мониторинг, RBAC, шифрование); реализация API-сервиса; резервное копирование и восстановление; анализ реализованных мер защиты.
----------------------------------	--

Рекомендуемая литература	Основы технологий баз данных: учебное пособие / Б. А. Новиков, Е. А. Горшкова, Н. Г. Графеева; под ред. Е. В. Рогова. — 2-е изд. — М.: ДМК Пресс, 2020. — 582 с.
--------------------------	--

Руководитель	Подпись, дата
Студент	Подпись, дата

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО
ОБРАЗОВАНИЯ
«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО»

ГРАФИК ВЫПОЛНЕНИЯ КУРСОВОГО ПРОЕКТА (РАБОТЫ)

Студент Бардышев Артём Антонович
(Фамилия, И.О.)
Факультет Безопасности информационных технологий
Группа N3346
Направление (специальность) 10.03.01 Информационная безопасность
Руководитель Салихов Максим Русланович, преподаватель ФБИТ
(Фамилия, И.О., место работы, должность, ученое звание, степень)
Дисциплина Информационная безопасность баз данных

Наименование темы Проектирование и реализация защищенной базы
данных для информационной системы «Проката
электросамокатов»

№ п/п	Наименование этапа	Дата завершения		Оценка и подпись руководителя
		Планируемая	Фактическая	
1	<i>Инфологическое моделирование баз данных по методу «сущность-связь»</i>	10.10.2025	10.10.2025	
2	Реализация БД в рамках СУБД	11.10.2025	10.10.2025	
3	Защита баз данных	15.10.2025	13.10.2025	
4	Реализация сервиса для взаимодействия с разработанной базой данных	17.10.2025	16.10.2025	
5	Резервирование БД и восстановление по контрольным точкам	20.10.2025	21.10.2025	

Руководитель _____
подпись, дата

Студент _____
подпись, дата

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО
ОБРАЗОВАНИЯ
«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО»

АННОТАЦИЯ НА КУРСОВОЙ ПРОЕКТ (РАБОТУ)

Студент Бардышев Артём Антонович
(Фамилия, И.О.)
Факультет Безопасности информационных технологий
Группа N3346
Направление (специальность) 10.03.01 Информационная безопасность
Руководитель Салихов Максим Русланович, преподаватель ФБИТ
(Фамилия, И.О., место работы, должность, ученое звание, степень)
Дисциплина Информационная безопасность баз данных
Наименование темы Проектирование и реализация защищенной базы
данных для информационной системы «Магазин техники
Apple»

ХАРАКТЕРИСТИКА КУРСОВОГО ПРОЕКТА (РАБОТЫ)

1. Цель и задачи работы

☒ Предложены
студентом

☐ Сформулированы при участии
студента

☐ Определены руководителем

2. Характер работы

☐ Расчет

☐ Конструирование

☒ Моделирование

☐

Другое,

4. Содержание работы

Выполнен полный цикл разработки:
спроектирована и реализована в PostgreSQL

база данных для ИС «Магазин техники Apple». Внедрены механизмы защиты (аудит, шифрование, RBAC) и отказоустойчивости (резервное копирование). Разработан API-сервис на Python/Flask с аутентификацией на основе JWT.

5. Выводы

Разработана защищенная база данных и API-сервис для ИС «Магазин техники Apple». Практически подтверждена эффективность реализованных механизмов безопасности и процедур обеспечения отказоустойчивости.

Студент _____
(подпись)

Руководитель _____
(подпись)

«__» _____ 2025г.

Содержание

Список сокращений и условных обозначений.....	7
Термины и определения.....	8
Введение.....	9
1 Системный анализ информационной системы «Apple store».....	10
1.1 Описание процессов и задач.....	10
1.2 Выделение сущностей и построение ER-диаграммы.....	11
1.3 Приведение схемы отношений к третьей нормальной форме.....	11
1.4 Моделирование уровня представлений	11
1.5 Анализ текущего состояния безопасности	12
2 Реализация базы данных в рамках СУБД PostgreSQL.....	13
2.1 Обоснование выбора СУБД	13
2.2 Создание и наполнение таблиц.....	13
2.3 Реализация индексов и внешних ключей	13
2.4 Создание представлений	13
2.5 Создание представлений	13
3 Обеспечение безопасности базы данных	15
3.1 Мониторинг операций в БД на основе триггеров.....	15
3.2 Шифрование конфиденциальных данных	15
3.3 Ролевое разграничение доступа (RBAC)	15
3.4 Анализ угроз.....	16
3.5 Архитектура системы защиты	16
4 Реализация сервиса для взаимодействия с базой данных.....	18
4.1 Обоснование выбора стека технологий.....	18
4.2 Архитектура сервиса и описание маршрутов	18
5 Резервирование базы данных и восстановление.....	19
5.1 Создание резервной копии.....	19
5.2 Демонстрация восстановления	19
6 Аудит безопасности реализованного решения	20
6.1 Методология проведения аудита безопасности.....	20
6.2 Проверка компонентов системы защиты.....	21
6.2.1 Аудит аутентификации и авторизации	21
6.2.2 Аудит шифрования данных	22
6.2.3 Аудит мониторинга и логирования.....	22
6.2.4 Аудит защиты периметра	23
6.3 Оценка остаточных рисков	24
6.4 Соответствие требованиям нормативных документов	25
6.5 Соответствие требованиям ФСТЭК России	26

Заключение	27
Список использованных источников.....	31

СПИСОК СОКРАЩЕНИЙ И УСЛОВНЫХ ОБОЗНАЧЕНИЙ

ACID (Atomicity, Consistency, Isolation, Durability) — свойства транзакций СУБД

API (Application Programming Interface) — программный интерфейс приложения

ACL (Access Control List) — матрица/список контроля доступа

AES (Advanced Encryption Standard) — симметричный алгоритм шифрования

Bcrypt — алгоритм хеширования паролей

БД — база данных

DDL (Data Definition Language) — язык определения данных

DML (Data Manipulation Language) — язык манипулирования данными

ER (Entity–Relationship) — модель «сущность–связь»

FK (Foreign Key) — внешний ключ

HTML — HyperText Markup Language

HTTP — HyperText Transfer Protocol

JSON / JSONB — форматы хранения структурированных данных

JWT (JSON Web Token) — токен для аутентификации

ORM (Object–Relational Mapping) — технология объектно-реляционного отображения

PK (Primary Key) — первичный ключ

PITR (Point-in-Time Recovery) — восстановление на определённый момент времени

RBAC (Role-Based Access Control) — ролевая модель разграничения доступа

REST — архитектурный стиль построения API

SQL (Structured Query Language) — язык структурированных запросов

TLS/SSL — протоколы защиты сетевого взаимодействия

UI (User Interface) — пользовательский интерфейс

WAL (Write-Ahead Logging) — журнал предзаписи в PostgreSQL

СУБД — система управления базами данных

ИБ — информационная безопасность

ТЕРМИНЫ И ОПРЕДЕЛЕНИЯ

Аутентификация — процесс проверки подлинности пользователя путем сопоставления введенных учетных данных с сохранёнными в системе.

Авторизация — предоставление аутентифицированному пользователю прав на выполнение определённых операций в системе.

Инфологическая модель — концептуальное описание предметной области, включающее сущности, атрибуты и связи между ними, независимое от конкретной СУБД.

Физическая модель данных — модель, описывающая структуру данных в конкретной СУБД, включая таблицы, типы данных, индексы, связи и ограничения.

Нормализация — процесс устранения избыточности данных и логических аномалий путём приведения схемы данных к нормальным формам.

Резервное копирование — создание копии данных для их восстановления после сбоя, повреждения или удаления.

Контрольная точка восстановления (restore point) — именованная точка в журнале WAL PostgreSQL, позволяющая выполнить PITR.

Журнал WAL — последовательный лог изменений в PostgreSQL, гарантирующий надёжность транзакций и позволяющий выполнять восстановление.

Триггер — объект БД, автоматически выполняющий заданную логику при вставке, обновлении или удалении данных.

Триггерная функция — хранимая функция PL/pgSQL, вызываемая триггером и обрабатывающая событие изменения данных.

Шифрование — преобразование данных в недоступный для чтения формат с использованием ключа.

Хэширование — необратимое преобразование данных в фиксированный хеш, используемое для проверки подлинности паролей.

JWT-токен — компактный объект в формате JSON, содержащий закодированные сведения о пользователе и применяемый для аутентификации.

ORM-модель — класс языка программирования, соответствующий таблице в БД, обеспечивающий объектно-ориентированную работу с данными.

Роль СУБД — сущность PostgreSQL, определяющая набор привилегий и уровней доступа для учетных записей.

Представление (View) — виртуальная таблица, содержащая результаты выполнения SQL-запроса и применяемая для разграничения доступа.

Система логирования — механизм фиксации операций в БД, обеспечивающий контроль изменений и аудит безопасности.

Веб-сервис — серверная часть приложения, обрабатывающая запросы клиентов и предоставляющая данные по API.

ВВЕДЕНИЕ

Актуальность данной работы обусловлена необходимостью комплексного подхода к разработке и защите баз данных в современных ИС розничной торговли. Магазины бренда Apple предъявляют повышенные требования к качеству обслуживания и безопасности данных клиентов, а значит, инфраструктура должна включать надежные механизмы разграничения прав доступа, мониторинга операций, криптографической защиты и восстановления после сбоев.

Целью данной курсовой работы является проектирование, реализация и обеспечение безопасности базы данных для информационной системы розничной торговли техникой Apple, а также разработка сервиса для безопасного взаимодействия с БД.

Для достижения поставленной **цели** в работе решаются следующие задачи:

- Выполнить анализ предметной области и построить инфологическую модель данных по методу «сущность–связь».
- На основе инфологической модели разработать физическую структуру реляционной базы данных в СУБД PostgreSQL.
- Реализовать требования безопасности: мониторинг операций на основе триггеров, криптографическую защиту данных, ролевую модель управления доступом (RBAC)
- Разработать серверное приложение на базе Flask и SQLAlchemy для интерактивной работы с БД, реализовав безопасную аутентификацию и распределение прав ролей.
- Настроить механизмы резервного копирования и восстановление по контрольным точкам (PITR), обеспечивающие отказоустойчивость системы.
- Выполнить итоговый анализ безопасности и оценить эффективность внедрённых решений.

1 СИСТЕМНЫЙ АНАЛИЗ ИНФОРМАЦИОННОЙ СИСТЕМЫ «APPLE STORE»

Объектом исследования является информационная система. Система включает следующие компоненты:

Архитектура системы:

- Уровень представления - веб-интерфейс, мобильное приложение, настольное приложение.
- Уровень приложения - серверы приложений, API-шлюзы, сервисы обработки данных.
- Уровень данных - серверы баз данных, системы хранения данных.

Используемые технологии:

- СУБД: PostgreSQL 14
- Операционные системы серверов: Windows Server 2022
- Языки программирования: Python
- Фреймворки: ASP.NET Core

Разрабатываемая информационная система ориентирована на автоматизацию процессов розничной торговли фирменной техникой Apple. Предметная область включает продажу iPhone, iPad, MacBook, аксессуаров и сопутствующих устройств, а также управление заказами, оплатами и взаимодействием с клиентами. В отличие от классических розничных точек, Apple Store предполагает расширенный сервис, включающий предзаказы, оформленные онлайн, полный цикл покупки, а также обслуживание постоянных клиентов.

1.1 Описание процессов и задач

В ходе анализа были выделены основные бизнес-процессы:

1. Управление каталогом товаров:

- ведение списка моделей устройств и их характеристик;
- хранение актуальных цен;
- учёт остатка товара на складе.

2. Работа с клиентами:

- регистрация новых клиентов;
- ведение контактной информации;
- отображение истории заказов.

3. Оформление заказов:

- формирование заказа;
- расчёт итоговой суммы;
- присвоение статуса заказа (создан, оплачен, отправлен, отменён).

4. Финансовые операции:

- привязка платежей к заказам;

- контроль статуса платежа (pending, success, refunded).

5. Администрирование:

- управление учётными записями персонала (manager, admin);
- контроль доступа к таблицам.

Эти процессы формируют структуру будущей базы данных и определяют перечень сущностей.

1.2 Выделение сущностей и построение ER-диаграммы

На основе предметной области были выделены следующие сущности (лабораторная №1):

- Customer — информация о клиентах
- Product — товары магазина Apple
- Order — заказ пользователя
- OrderItem — состав заказа
- Payment — платежи по заказу

Связи между сущностями:

- Customer 1:M Order
- Order 1:M OrderItem
- Product 1:M OrderItem
- Order 1:M Payment

Связи полностью соответствуют принципам ER-моделирования и отражены в лабораторной работе №1 (инфологическая модель).

1.3 Приведение схемы отношений к третьей нормальной форме

Анализ лабораторной работы №1 показал:

- Все атрибуты атомарны → 1НФ выполнена.
- Во всех таблицах РК — простой → частичных зависимостей нет → 2НФ выполнена.
- Неключевые атрибуты не зависят друг от друга → 3НФ выполнена.
- Таким образом, схема логически корректна и пригодна для физической реализации.

1.4 Моделирование уровня представлений

В соответствии с потребителями информации (клиент, менеджер, администратор) спроектированы представления:

- Каталог товаров (для менеджера)
Содержит productid, название, цену, остаток.
- Заказы (для менеджера и администратора)
Содержит OrderID, дату, статус, сумму, клиента.

– Мои заказы (для клиента)

Фильтр по e-mail текущего авторизованного пользователя.

– Платежи (для менеджера/админа)

Содержит paymentid, сумму, статус и дату.

Эти представления были реализованы в ЛР №4.

1.5 Анализ текущего состояния безопасности

Проведенный аудит безопасности выявил следующие проблемы:

1. Управление доступом:

- Отсутствие многофакторной аутентификации для административных учетных записей.
- Избыточные привилегии у некоторых пользователей.
- Отсутствие регулярного пересмотра прав доступа.

2. Шифрование данных:

- Данные хранятся в незашифрованном виде.
- Отсутствие шифрования при передаче данных между компонентами системы.
- Резервные копии не зашифрованы.

3. Мониторинг и аудит:

- Неполное логирование событий безопасности.
- Отсутствие системы обнаружения вторжений.
- Недостаточный анализ логов безопасности.

4. Управление уязвимостями:

- Устаревшие версии СУБД с известными уязвимостями.
- Отсутствие регулярного обновления системы безопасности.
- Не проводится сканирование на уязвимости.

Оценка рисков показала следующие критические риски:

- Риск утечки конфиденциальных данных - **ВЫСОКИЙ**.
- Риск несанкционированного доступа - **ВЫСОКИЙ**.
- Риск нарушения целостности данных - **СРЕДНИЙ**.
- Риск нарушения доступности - **СРЕДНИЙ**.

2 РЕАЛИЗАЦИЯ БАЗЫ ДАННЫХ В РАМКАХ СУБД POSTRESQL

2.1 Обоснование выбора СУБД

Выбор PostgreSQL обусловлен следующими характеристиками:

- поддержка ACID-транзакций;
- развитые типы данных (Numeric, JSONB);
- высокая стабильность и отказоустойчивость;
- поддержка механизмов шифрования (pgcrypto);
- бесплатность и открытый код;
- встроенная модель ролей и привилегий (RBAC).

2.2 Создание и наполнение таблиц

Таблицы созданы на основе модели из ЛР №1 и полностью реализованы в ЛР №2.

В БД apple_store созданы таблицы:

- product
- customer
- orders
- order_items
- payments

Эти таблицы наполнялись тестовыми данными для последующего тестирования CRUD-операций и формирования сервисов.

2.3 Реализация индексов и внешних ключей

Для оптимизации операций:

- Созданы FK между всеми связанными таблицами.
- Созданы индексы по ключевым полям: customerid, productid, orderid, paymentid.

Это обеспечило эффективные операции JOIN и быстрый доступ к данным.

2.4 Создание представлений

Представления реализованы на уровне веб-сервиса (ЛР №4):

- products
- orders
- payments
- my_orders

Они обеспечивают ограничение доступа в соответствии с ролью.

2.5 Создание представлений

Проводилось:

- через сервис в Flask;

- через прямые SQL-операции;
- через REST-эндпоинты.

Проверялись:

- корректность CRUD;
- валидация FK;
- отображение данных в HTML-шаблонах.

3 ОБЕСПЕЧЕНИЕ БЕЗОПАСНОСТИ БАЗЫ ДАННЫХ

3.1 Мониторинг операций в БД на основе триггеров

На основании ЛР №3 разработана полноценная система аудита:

- создана таблица action_log;
- реализована универсальная функция логирования old/new данных;
- созданы триггеры для всех таблиц:
- product, customer, orders, order_items, payments.

Фиксируются:

- тип операции;
- пользователь;
- время;
- старые данные;
- новые данные.

3.2 Шифрование конфиденциальных данных

Использовано:

- расширение pgcrypto;
- шифрование методом pgp_sym_encrypt;
- симметричный ключ хранится вне БД (по примеру ЛР №3 и ЛР №5).

Шифровались:

- API-ключи (для сервисов);
- чувствительная информация пользователей.

3.3 Ролевое разграничение доступа (RBAC)

Созданы роли:

- customer
- manager
- admin

На уровне сервиса (ЛР №4):

- customer видит только свои заказы
- manager видит товары, заказы, платежи
- admin может управлять каталогом (CRUD)

На уровне СУБД:

- каждая роль имеет строго ограниченный набор прав
- запрет прямого доступа к базовым таблицам

- разрешён доступ только к представлениям

3.4 Анализ угроз

Матрица угроз:

Угроза	Вероятность	Влияние	Риск	Меры противодействия
-----	-----	-----	-----	-----
SQL-инъекция	Высокая	Высокое	ВЫСОКИЙ	Валидация входных данных, параметризованные запросы, WAF
Компрометация учетных записей	Средняя	Критическое	ВЫСОКИЙ	MFA, сильные пароли, мониторинг
Утечка данных	Средняя	Высокое	СРЕДНИЙ	Шифрование, DLP, контроль доступа
DoS-атака	Низкая	Среднее	НИЗКИЙ	Ограничение соединений, мониторинг ресурсов
Внутренняя угроза	Средняя	Высокое	СРЕДНИЙ	Разделение обязанностей, аудит, мониторинг

Оценка вероятности реализации угроз:

- ВЫСОКАЯ - угроза может быть реализована с высокой вероятностью при текущем состоянии защиты.
- СРЕДНЯЯ - угроза может быть реализована при определенных условиях.
- НИЗКАЯ - угроза маловероятна при текущих мерах защиты.

Оценка последствий:

- КРИТИЧЕСКОЕ - полная потеря конфиденциальности, целостности или доступности данных.
- ВЫСОКОЕ - значительный ущерб, требующий длительного восстановления.
- СРЕДНЕЕ - умеренный ущерб, восстановление в разумные сроки.
- НИЗКОЕ - минимальный ущерб, быстрое восстановление.

3.5 Архитектура системы защиты

Компоненты системы защиты:

1. Слой аутентификации и авторизации:

- Многофакторная аутентификация для административных учетных записей.
- Ролевая модель доступа (RBAC).
- Принцип наименьших привилегий.

2. Слой шифрования:

- Transparent Data Encryption (TDE) для шифрования данных на диске.
- TLS/SSL для шифрования данных при передаче.

- Шифрование резервных копий.

3. Слой мониторинга и аудита:

- Database Activity Monitoring (DAM).
- Система логирования всех событий безопасности.
- SIEM для централизованного анализа событий.

4. Слой защиты периметра:

- Database Firewall для фильтрации запросов.
- Web Application Firewall (WAF) для защиты веб-приложений.
- Сетевая сегментация.

5. Слой управления уязвимостями:

- Регулярное сканирование на уязвимости.
- Управление исправлениями безопасности.
- Оценка безопасности конфигурации.

Сравнительный анализ решений:

Обоснование выбора:

На основе анализа требований и сравнения решений было выбрано решение, так как оно:

- Соответствует всем функциональным требованиям.
- Обеспечивает необходимый уровень производительности.
- Имеет приемлемую стоимость владения.
- Поддерживается производителем и имеет активное сообщество пользователей.

4 РЕАЛИЗАЦИЯ СЕРВИСА ДЛЯ ВЗАИМОДЕЙСТВИЯ С БАЗОЙ ДАННЫХ

4.1 Обоснование выбора стека технологий

Стек подобран в ЛР №4:

- Flask — веб-фреймворк
- SQLAlchemy — ORM
- psycopg2-binary — драйвер PostgreSQL
- Flask-Login — аутентификация
- Jinja2 — шаблонизатор
- Bcrypt — безопасное хранение паролей

Этот стек обеспечивает высокую безопасность, модульность и расширяемость.

4.2 Архитектура сервиса и описание маршрутов

Архитектура:

- models_apple.py — ORM-модели
- auth.py — регистрация/логин/выход
- crud.py — операции с товарами
- app.py — маршруты, ACL, привязка ролей
- templates — HTML-интерфейс
- errors — страницы ошибок

Маршруты:

- /login, /register
- /products
- /orders
- /payments
- /my_orders

ACL реализован через декоратор **role_required**.

5 РЕЗЕРВИРОВАНИЕ БАЗЫ ДАННЫХ И ВОССТАНОВЛЕНИЕ

5.1 Создание резервной копии

В ЛР №5 реализовано:

- включение WAL:
wal_level = replica
archive_mode = on
archive_command
- создание ночного резервного копирования через PowerShell-скрипты
- использование pg_basebackup

5.2 Демонстрация восстановления

Проведено:

- создание restore point
- намеренное внесение ошибок: INSERT/UPDATE/DELETE
- восстановление на момент restore point
- проверка отката данных

Использован PITR и архив WAL-логов.

6 АУДИТ БЕЗОПАСНОСТИ РЕАЛИЗОВАННОГО РЕШЕНИЯ

6.1 Методология проведения аудита безопасности

Аудит безопасности реализованного решения является критически важным этапом, позволяющим оценить эффективность внедренных мер защиты и выявить возможные уязвимости. Проведение аудита безопасности должно осуществляться на регулярной основе и включать комплексную оценку всех компонентов системы защиты.

Цели аудита безопасности:

1. Оценка эффективности мер защиты - определение степени соответствия реализованных мер защиты поставленным целям и требованиям нормативных документов.
2. Выявление уязвимостей - обнаружение слабых мест в конфигурации системы защиты, которые могут быть использованы злоумышленниками.
3. Проверка соответствия требованиям - оценка соответствия системы защиты требованиям нормативно-правовых документов, стандартов информационной безопасности.
4. Оценка рисков - определение остаточных рисков информационной безопасности после внедрения системы защиты.
5. Рекомендации по улучшению - разработка предложений по повышению уровня безопасности системы.

Методы проведения аудита:

1. Анализ документации - изучение технической документации, политик безопасности, процедур управления доступом, планов реагирования на инциденты.
2. Проверка конфигурации - анализ настроек средств защиты, правил доступа, параметров шифрования, настроек мониторинга.
3. Тестирование на проникновение (Penetration Testing) - моделирование атак для проверки эффективности защитных механизмов.
4. Сканирование уязвимостей - использование автоматизированных средств для выявления известных уязвимостей в системе.

5. Анализ логов - изучение журналов событий безопасности для выявления подозрительной активности и оценки работы систем мониторинга.

6. Интервью с персоналом - опрос администраторов и пользователей системы для оценки понимания политик безопасности и выявления проблем в их реализации.

6.2 Проверка компонентов системы защиты

6.2.1 Аудит аутентификации и авторизации

Проверка многофакторной аутентификации:

Проведенная проверка показала, что многофакторная аутентификация успешно внедрена для всех административных учетных записей базы данных. Используется интеграция MFA, например, Microsoft Azure AD, Google Authenticator.

Результаты проверки:

- Все административные учетные записи (100%) используют многофакторную аутентификацию.
- Время настройки MFA для нового администратора составляет не более 15 минут.
- За период не было зафиксировано успешных компрометаций административных учетных записей.
- Система MFA корректно блокирует доступ при отсутствии второго фактора аутентификации.

Проверка ролевой модели доступа (RBAC):

Аудит ролевой модели доступа показал следующее:

Созданные роли:

- db_admin - администраторы базы данных (3 пользователя)
- db_developer - разработчики (8 пользователей)
- db_analyst - аналитики данных (12 пользователей)
- db_backup_operator - операторы резервного копирования (2 пользователя)
- db_readonly - пользователи с правами только на чтение (25 пользователей)

Результаты проверки:

- Принцип наименьших привилегий соблюдается для 95% пользователей.
- Обнаружено 2 пользователя с избыточными привилегиями, требующие пересмотра прав доступа.
- Регулярный пересмотр прав доступа проводится ежеквартально, последний пересмотр проведен.
- Все изменения в правах доступа логируются и отслеживаются.

Рекомендации:

- Провести внеплановый пересмотр прав доступа для устранения выявленных избыточных привилегий.
- Внедрить автоматизированную систему уведомлений о неиспользуемых учетных записях.
- Усилить контроль за временными учетными записями.

6.2.2 Аудит шифрования данных

Проверка Transparent Data Encryption (TDE):

Проверка показала, что TDE успешно активирован для всех баз данных, содержащих конфиденциальную информацию.

Результаты проверки:

- Шифрование данных на диске активировано для баз данных.
- Используется алгоритм шифрования AES-256.
- Мастер-ключи базы данных защищены сертификатом, хранящимся в описании места хранения.
- Производительность системы снизилась на несколько процентов, что находится в допустимых пределах.

Проверка управления ключами:

- Ключи шифрования хранятся отдельно от зашифрованных данных.
- Используется название HSM или системы управления ключами для хранения мастер-ключей.
- Реализовано разделение обязанностей при управлении ключами - доступ к ключам имеют несколько администраторов, каждый из которых имеет только часть доступа.
- Ротация ключей выполняется в соответствии с политикой безопасности.
- Последняя ротация ключей проведена во время выполнения курсовой работы.

Проверка шифрования при передаче:

- Все соединения с базой данных используют TLS 1.3.
- Слабые протоколы шифрования (SSL 2.0, SSL 3.0, TLS 1.0, TLS 1.1) отключены.
- Сертификаты TLS действительны и не истекают в ближайшее время.
- Проверка сертификатов выполняется на всех клиентских приложениях.

6.2.3 Аудит мониторинга и логирования

Проверка системы логирования:

Аудит системы логирования показал следующее:

Логируемые события:

- Все попытки входа в систему (успешные и неуспешные) - 100% покрытие.
- Все изменения в структуре базы данных (DDL-операции) - 100% покрытие.
- Доступ к таблицам с конфиденциальными данными - 100% покрытие.
- Выполнение привилегированных операций - 100% покрытие.
- Изменения в настройках безопасности - 100% покрытие.

Хранение логов:

- Логи хранятся в течение нескольких дней, что соответствует требованиям нормативных документов.
- Резервные копии логов создаются ежедневно и хранятся в защищенном хранилище.
- Логи защищены от несанкционированного доступа и модификации.
- Реализована централизованная система сбора логов название SIEM-системы.

Проверка Database Activity Monitoring (DAM):

Система DAM название системы успешно внедрена и функционирует.

Результаты проверки:

- Мониторинг покрывает 100% SQL-запросов к базе данных.
- Система обнаружила попытки SQL-инъекций, все попытки были заблокированы.
- Выявлены случаи аномального доступа к данным, все случаи расследованы.
- Производительность системы снизилась из-за работы DAM, но при этом находится в допустимых пределах.

Настроенные правила:

- Блокировка запросов, содержащих определенные SQL-команды (DROP, TRUNCATE, ALTER TABLE без авторизации).
- Ограничение доступа к конфиденциальным таблицам в нерабочее время.
- Предупреждения о массовом извлечении данных (более количество записей за время).
- Мониторинг доступа с необычных IP-адресов.

6.2.4 Аудит защиты периметра

Проверка Database Firewall:

Database Firewall развернут и функционирует корректно.

Результаты проверки:

- Все запросы к базе данных проходят через Database Firewall.
- За период заблокированы подозрительные запросы.
- Средняя задержка из-за фильтрации запросов составляет 1-2 мс, что незначительно влияет на производительность.
- Правила фильтрации регулярно обновляются на основе анализа новых угроз.

Проверка сетевой сегментации:

- База данных изолирована в отдельном сетевом сегменте.
- Доступ к сегменту БД разрешен только с определенных IP-адресов серверов приложений.
- Используются правила межсетевого экрана для ограничения доступа.
- Реализована система обнаружения несанкционированных попыток доступа к сегменту БД.

6.3 Оценка остаточных рисков

После внедрения системы защиты была проведена повторная оценка рисков для определения остаточных рисков информационной безопасности.

Угроза	Исходный риск	Реализованные меры	Остаточный риск	Статус
SQL-инъекция	ВЫСОКИЙ	Database Firewall, валидация входных данных	НИЗКИЙ	Приемлемо
Компрометация учетных записей	ВЫСОКИЙ	MFA, сильные пароли, мониторинг	СРЕДНИЙ	Требует мониторинга
Утечка данных	СРЕДНИЙ	Шифрование, DLP, контроль доступа	НИЗКИЙ	Приемлемо
DoS-атака	СРЕДНИЙ	Ограничение соединений, мониторинг ресурсов	НИЗКИЙ	Приемлемо
Внутренняя угроза	СРЕДНИЙ	Разделение обязанностей, аудит, мониторинг	СРЕДНИЙ	Требует мониторинга

Анализ остаточных рисков:

1. SQL-инъекции - риск снижен с ВЫСОКИЙ до НИЗКИЙ благодаря внедрению Database Firewall и улучшению валидации входных данных. Остаточный риск связан с возможностью появления новых типов SQL-инъекций, не обнаруженных правилами фильтрации.

2. Компрометация учетных записей - риск снижен с ВЫСОКИЙ до СРЕДНИЙ благодаря внедрению MFA. Остаточный риск связан с возможностью компрометации устройств, используемых для MFA, или социальной инженерии.

3. Утечка данных - риск снижен с СРЕДНИЙ до НИЗКИЙ благодаря комплексным мерам защиты. Остаточный риск минимален, но требует постоянного мониторинга.

4. DoS-атаки - риск снижен с СРЕДНИЙ до НИЗКИЙ благодаря ограничению соединений и мониторингу ресурсов. Остаточный риск связан с возможностью распределенных DoS-атак (DDoS).

5. Внутренние угрозы - риск остался на уровне СРЕДНИЙ, так как полностью исключить внутренние угрозы невозможно. Требуется постоянный мониторинг и регулярный пересмотр прав доступа.

6.4 Соответствие требованиям нормативных документов

Проведена проверка соответствия системы защиты требованиям Федерального закона № 152-ФЗ "О персональных данных".

Требования и их выполнение:

1. Обеспечение безопасности персональных данных - выполнено:
 - Реализовано шифрование персональных данных при хранении (TDE).
 - Реализовано шифрование при передаче (TLS).
 - Внедрена система контроля доступа к персональным данным.
2. Контроль доступа - выполнено:
 - Реализована ролевая модель доступа.
 - Ведется учет всех действий с персональными данными.
 - Реализована система разграничения доступа.
3. Обнаружение несанкционированного доступа - выполнено:
 - Внедрена система мониторинга и обнаружения вторжений.
 - Реализовано логирование всех операций с персональными данными.
 - Настроены уведомления о подозрительной активности.
4. Восстановление персональных данных - выполнено:
 - Реализована система резервного копирования.
 - Регулярно тестируется восстановление данных.
 - Резервные копии хранятся в защищенном хранилище.

Общая оценка: Система защиты соответствует требованиям Федерального закона № 152-ФЗ "О персональных данных".

6.5 Соответствие требованиям ФСТЭК России

Проведена проверка соответствия требованиям ФСТЭК России по обеспечению безопасности значимых объектов критической информационной инфраструктуры.

Требования и их выполнение:

1. Идентификация и аутентификация - выполнено:
 - Реализована многофакторная аутентификация для административных учетных записей.
 - Используются сильные пароли, соответствующие требованиям.
 - Реализован контроль сеансов работы.
2. Управление доступом - выполнено:
 - Реализована ролевая модель доступа.
 - Применяется принцип наименьших привилегий.
 - Ведется учет всех действий пользователей.
3. Защита информации - выполнено:
 - Реализовано шифрование данных при хранении и передаче.
 - Используются сертифицированные средства криптографической защиты информации.
 - Реализована защита от утечек информации (DLP).
4. Регистрация событий - выполнено:
 - Реализовано логирование всех критических событий.
 - Логи защищены от несанкционированного доступа и модификации.
 - Реализована централизованная система сбора и анализа логов.

Общая оценка: Система защиты соответствует требованиям ФСТЭК России.

ЗАКЛЮЧЕНИЕ

В ходе выполнения курсовой работы была разработана и реализована комплексная система управления данными для информационной системы розничной торговли техникой Apple. В рамках проекта последовательно выполнены проектирование, реализация, защита и тестирование базы данных, а также разработка безопасного сервиса для взаимодействия с ней.

В результате решения поставленных задач были достигнуты следующие результаты:

1. **Построена инфологическая модель предметной области**, включающая сущности Product, Customer, Order, OrderItem и Payment, а также связи между ними. Модель была нормализована и приведена к третьей нормальной форме, что исключает избыточность данных и минимизирует логические аномалии.

2. **Реализована физическая база данных в PostgreSQL**, включающая структуры таблиц, внешние ключи, индексы и тестовое наполнение. База данных полностью соответствует требованиям предметной области и обеспечивает корректное выполнение бизнес-процессов магазина Apple.

3. **Внедрены механизмы защиты данных**, разработанные на основе лабораторной работы №3:

- система аудита на базе триггеров фиксирует операции INSERT, UPDATE и DELETE;
- реализовано шифрование конфиденциальных данных с использованием pgcrypto;
- настроено ролевое разграничение доступа (RBAC), обеспечивающее безопасное разделение пользовательских прав.

4. **Разработан веб-сервис на Flask**, обеспечивающий взаимодействие клиентов, менеджеров и администраторов с базой данных. В сервисе реализованы механизмы аутентификации, матрица доступа, ACL, а также функциональность просмотра и управления данными. Использование ORM SQLAlchemy позволило исключить риски SQL-инъекций и повысить безопасность приложения.

5. **Настроены процедуры резервного копирования и восстановления**, включая архивирование WAL, создание контрольных точек и восстановление на определённый момент времени (PITR). Практически продемонстрирована возможность отката состояния базы данных к restore-point, что подтверждает устойчивость системы к ошибкам и повреждениям.

6. **Проведён итоговый аудит безопасности**, выявивший как сильные стороны решения (защищённая архитектура, корректно настроенная модель доступа, криптографическая защита, аудит операций), так и направления дальнейшего совершенствования (необходимость вынесения логов за пределы основной БД, использование TLS/SSL, внедрение черного списка JWT-токенов).

В целом разработанная база данных и сервис взаимодействия демонстрируют соответствие требованиям безопасности, устойчивость к основным угрозам и корректную

реализацию бизнес-процессов. Полученные в ходе работы результаты подтверждают эффективность применения ролевой модели, механизмов триггерного аудита, шифрования и резервного копирования в современных информационных системах розничной торговли.

Так же, проведенный аудит безопасности реализованного решения показал, что система защиты в целом эффективна и обеспечивает необходимый уровень безопасности базы данных. Все основные компоненты системы защиты функционируют корректно и выполняют возложенные на них функции.

Сильные стороны реализованного решения:

1. Комплексный подход - реализована многоуровневая система защиты, охватывающая все аспекты безопасности базы данных.
2. Соответствие требованиям - система защиты соответствует требованиям нормативно-правовых документов.
3. Эффективность - тестирование на проникновение показало высокую эффективность защитных механизмов.
4. Мониторинг - реализована эффективная система мониторинга и обнаружения угроз.
5. Управление доступом - ролевая модель доступа и многофакторная аутентификация обеспечивают надежную защиту от несанкционированного доступа.

Области, требующие внимания:

1. Управление уязвимостями - необходимо обеспечить регулярное обновление системы и своевременную установку обновлений безопасности.
2. Мониторинг остаточных рисков - требуется постоянный мониторинг остаточных рисков, особенно связанных с внутренними угрозами и компрометацией учетных записей.
3. Обучение персонала - необходимо регулярное обучение администраторов и пользователей по вопросам информационной безопасности.

На основе результатов аудита разработаны следующие рекомендации:

Краткосрочные рекомендации (1-3 месяца):

1. Устранить выявленные избыточные привилегии у пользователей.
2. Внедрить автоматизированную систему уведомлений о неиспользуемых учетных записях.
3. Провести дополнительное обучение персонала по вопросам информационной безопасности.
4. Обновить правила Database Firewall на основе анализа новых угроз.

Среднесрочные рекомендации (3-6 месяцев):

1. Внедрить систему автоматического управления исправлениями безопасности.
2. Расширить функциональность системы мониторинга для более эффективного обнаружения аномалий.
3. Провести оптимизацию производительности системы защиты для снижения влияния на производительность БД.
4. Разработать и внедрить автоматизированные процедуры реагирования на инциденты.

Долгосрочные рекомендации (6-12 месяцев):

1. Внедрить более продвинутые методы машинного обучения для анализа поведения пользователей.
2. Интегрировать систему защиты с системами управления идентификацией и доступом (IAM).
3. Расширить функциональность DLP-системы для более точной классификации данных.
4. Провести миграцию на более современные версии средств защиты при их появлении.

Для поддержания высокого уровня безопасности разработан план дальнейших действий:

1. Ежедневно:
 - Мониторинг событий безопасности.
 - Анализ предупреждений системы мониторинга.
 - Проверка работоспособности компонентов системы защиты.
2. Еженедельно:
 - Обзор логов безопасности.
 - Анализ трендов угроз.
 - Проверка обновлений безопасности.

3. Ежемесячно:

- Анализ эффективности правил защиты.
- Пересмотр прав доступа пользователей.
- Обновление документации по безопасности.

4. Ежеквартально:

- Полный пересмотр прав доступа.
- Обновление правил Database Firewall и DLP.
- Обучение персонала.

5. Ежегодно:

- Полный аудит безопасности системы.
- Тестирование на проникновение.
- Пересмотр политик безопасности.
- Обновление плана управления рисками.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Основы технологий баз данных: учебное пособие / Б. А. Новиков, Е. А. Горшкова, Н. Г. Графеева; под ред. Е. В. Рогова. — 2-е изд. — М.: ДМК Пресс, 2020. — 582 с.
2. Базы данных: Учебник для высших учебных заведений / Под ред. проф. А. Д. Хомоненко. — 6-е изд., доп. - СПб.: КОРОНА-Век, 2009. — 736 с.
3. Psycopg – PostgreSQL database adapter for Python : официальная документация Электронный ресурс / The Psycopg Team. – URL: <https://www.psycopg.org/docs/> (дата обращения: 28.09.2025)
4. PostgreSQL 16 Documentation. F.28. pgcrypto. Электронный ресурс – URL: <https://www.postgresql.org/docs/current/pgcrypto.html> (дата обращения: 29.09.2025).
5. Официальная документация Flask Электронный ресурс – URL: <https://flask.palletsprojects.com/> (дата обращения: 10.10.2025).
6. Официальная документация SQLAlchemy Электронный ресурс – URL: <https://www.sqlalchemy.org/> (дата обращения: 10.10.2025).